CYBERVSI



Web Application Security Assessment Report

COMPREHENSIVE PUBLIC SAMPLE

PREPARED BY	CyberVSI Security Testing
PREPARED FOR	Sample Organization
REPORT DATE	22 December 2025
DOCUMENT VERSION	V2.1 - Sanitized Sample
CLASSIFICATION	Public sample - fictionalized and sanitized

SAMPLE DATA NOTICE

All client names, contacts, systems, domains, IP addresses and evidence images have been removed or replaced. This document demonstrates report format only.

connect@cybervsi.com | service.cybervsi.com

Document History

SR.NO.	VERSION	DATE OF APPROVAL	COMMENT
1	1.0	3rd October 2025	Initial Assessment Report
2	1.0.1	7th October 2025	Segregated Web application Initial Assessment Report
3	2.0	22nd December 2025	Final Assessment Report -draft
4	2.1	22nd December 2025	Final Assessment Report

PUBLIC SAMPLE © 2026 CYBERVSI

TABLE OF CONTENT

1. GENERAL OVERVIEW	4
1.1 CONFIDENTIALITY STATEMENT	4
1.2 DISCLAIMER	4
1.3 CONTACT INFORMATION	4
2. ASSESSMENT OVERVIEW	5
2.1 Assessment Components	5
2.1.1 Vulnerability Assessment	5
2.1.2 Penetration Testing	6
3. EXECUTIVE SUMMARY	7
3.1 Overview	7
3.2 Severity Rating of Vulnerabilities	7
3.3 Classification of Vulnerability Status	8
3.4 Security Posture and Risk Calculation	8
3.5 Scope of Assessment	10
3.6 Graphical Summary of Key Findings	10
3.7 Comprehensive vulnerability status post-mitigation	11
3.8 Vulnerability Overview – Status, Severity & CVSS Rating	12
4. DETAILS OF IDENTIFIED VULNERABILITIES IN WEB APPLICATION	13
5. POST INITIAL ENGAGEMENT REVIEW and SECURITY RECOMMENDATIONS	42
6. POST FINAL ENGAGEMENT REVIEW and SECURITY RECOMMENDATIONS	43
7. COMPLIANCE MAPPING OF IDENTIFIED VULNERABILITIES	44
8. DOCUMENT APPROVAL DETAILS	47

PUBLIC SAMPLE © 2026 CYBERVSI

1. GENERAL OVERVIEW

1.1 Confidentiality Statement

This document is the exclusive property of CYBERVSI CyberVSI and Sample Organization
This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires the consent of CyberVSI and Sample Organization CyberVSI may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

1.2 Disclaimer

This Application Security Assessment provides a snapshot of Sample Organization s Applications security posture at the time of assessment. The findings and recommendations are based on the information available during the evaluation period and do not account for any changes or modifications made afterward.

Given the time constraints of such engagements, it is impossible to thoroughly evaluate all security controls. Therefore, the Penetration Tester prioritizes identifying and assessing the weakest security controls that could be exploited by attackers.

To maintain the effectiveness of your security measures, it is advisable to conduct similar assessments annually. These assessments should be performed either by internal teams or third-party assessors to ensure continuous improvement and adaptation of security controls to emerging threats.

1.3 Contact information

CyberVSI	
Security Testing Team	connect@cybervsi.com

Sample Organization	
Client Security Contact	client-contact@example.test

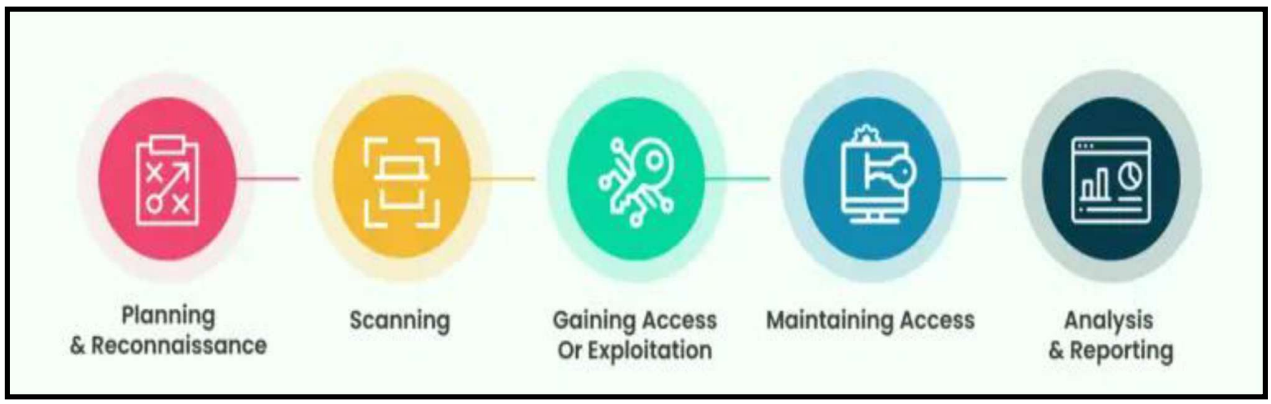
PUBLIC SAMPLE © 2026 CYBERVSI

2. ASSESSMNET OVERVIEW

The Web application testing is performed based on the NIST SP 800-115 Technical Guide to Information Security Testing and Assessment, the OWASP Testing Guide (v4.2), and customized testing frameworks.

The phases of penetration testing activities include:

- **Planning**: Gather customer goals and obtain rules of engagement.
- **Scanning**: Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- **Exploitation**: Confirm potential vulnerabilities through exploitation and discover additional weaknesses upon gaining new access.
- **Maintaining Access**: If exploitation is successful, the Penetration Tester will attempt to maintain access to the exploited system.
- **Reporting**: Document all identified vulnerabilities and exploits, any failed attempts, and the strengths and weaknesses of the company.



2.1 Assessment Components

2.1.1 Vulnerability Assessment

A vulnerability assessment was conducted to identify known security weaknesses across both web and thick-client applications. Automated tools such as OWASP ZAP, Burp Suite, Nessus, and Nmap were utilized to detect issues including injection flaws, cross-site scripting (XSS), insecure configurations, outdated components, and weak authentication mechanisms. For thick-client environments, the assessment also covered insecure local storage and API interactions. All findings were categorized by severity using CVSS metrics and accompanied by remediation guidance.

PUBLIC SAMPLE © 2026 CYBERVSI

2.1.2 Penetration Testing

Penetration testing was performed to validate the exploitability of identified vulnerabilities and uncover deeper systemic flaws. This included simulating real-world attack scenarios across web application. Web application testing focused on session management, access control, and privilege escalation paths. A combination of automated tools and manual techniques was employed to demonstrate actual risk through proof-of-concept exploits.

PUBLIC SAMPLE © 2026 CYBERVSI

3. EXECUTIVE SUMMARY

3.1 Overview

This Web Application Security Assessment Report presents a thorough evaluation of the security landscape of **Web application** conducted from **16/09/2025 to 26/09/2025**. The assessment was undertaken to proactively identify exploitable vulnerabilities, gauge system resilience against real-world attack scenarios, and deliver strategic, actionable guidance for fortifying infrastructure and application security.

In alignment with established frameworks such as OWASP Top 10, NIST SP 800-115, and CVSS v3.1, the engagement involved a hybrid approach combining advanced automated scanning tools and in-depth manual testing. Each vulnerability was validated for accuracy and classified based on potential impact to confidentiality, integrity, and availability.

This report is formally submitted to Sample Organization The findings herein are intended to support informed decision-making, enhance threat preparedness, and contribute to ongoing security governance efforts within the organization.

3.2 Severity Rating of Vulnerabilities.

The table below outlines the levels of severity and their corresponding CVSS score ranges, which are used throughout this document to assess vulnerabilities and their associated risk impacts.

Severity	CVSS V3.1 Range	Definition
Critical	9.0-10.0	Exploitation is straightforward and typically results in system-level compromise. Immediate action and patching are strongly recommended to mitigate this vulnerability.
High	7.0-8.9	Exploitation is more challenging but could result in elevated privileges and potentially lead to data loss or downtime. It is recommended to develop a plan of action and apply patches as soon as possible.
Medium	4.0-6.9	Vulnerabilities are present, but they are not directly exploitable or may require additional steps, such as social engineering, to be leveraged. It is advisable to develop a plan of action and address these vulnerabilities after resolving higher-priority issues.
Low	0.1-3.9	Vulnerabilities are non-exploitable but addressing them would reduce the organization's attack surface. It is recommended to develop a plan of action and apply patches during the next maintenance window.
Informational	0.0(None)	No impact to confidentiality, integrity, or availability. Typically indicates informational findings such as version disclosures or unnecessary services. These are for awareness only and do not require immediate remediation.

PUBLIC SAMPLE © 2026 CYBERVSI

3.3 Classification of Vulnerability Status

Vulnerability Status	Description
Open	The initial status of all vulnerabilities reported will be “Open”.
Resolved	The status of the vulnerability will be updated from Open to “Resolved” accompanied by a clear business justification. The severity level, CVSS of the reported vulnerability may be adjusted based on its actual impact and associated risk.
Risk-accepted	The status of the vulnerability will be updated from Open to “Risk Accepted” accompanied by ***Reason for risk acceptance, Risk acceptance approval from the (L2 or above manager), Tentative fix-deadline, Fix plan.***
Closed	All vulnerabilities with properly implemented mitigation measures will be marked as “Closed”. Vulnerabilities that are verified as false positives will also be marked as “Closed” with supporting evidence.

3.4 Security Posture and Risk Calculation

Risk Score Calculation	
Formula	Risk Score = (Critical × 16) + (High × 8) + (Medium × 4) + (Low × 2)
Calculation (pre-mitigation)	Risk Score = (0 × 16) + (0 × 8) + (3 × 4) + (7 × 2)
Calculation (post-mitigation)	Risk Score = (0 × 16) + (0 × 8) + (0 × 4) + (2 × 2)
Risk Score of Web application (pre-mitigation)	**26**
Risk Score of Web application (post-mitigation)	**4**

PUBLIC SAMPLE © 2026 CYBERVSI

Security Posture Score Calculation	
Formula	Security Score = 10 - (Risk Score / 10)
Calculation (pre-mitigation)	Security posture Score of the application= 10- (26/10)
Calculation (post-mitigation)	Security posture Score of the application= 10- (4/10)
Security Posture Score (pre-mitigation) – Web Application	**7.4**
Security Posture Score (post-mitigation)	**9.6**

Security Classification of the Application based on Security Posture Score	
0.0-3.9	Extremely Vulnerable
4.0-6.9	Vulnerable
7.0-8.9	Moderately Vulnerable
9.0-9.9	**Moderately Secure**
10.0	Secure

The application's pre-mitigation security score is 7.4 out of 10, indicating that the application is **Moderately Vulnerable** and the need for remediation.

The application's post-mitigation security score, with residual risk acceptance, is 9.6 out of 10. This reflects that the application is **Moderately Secure**, with all necessary security measures already implemented; however, application-level vulnerability mitigations remain required.

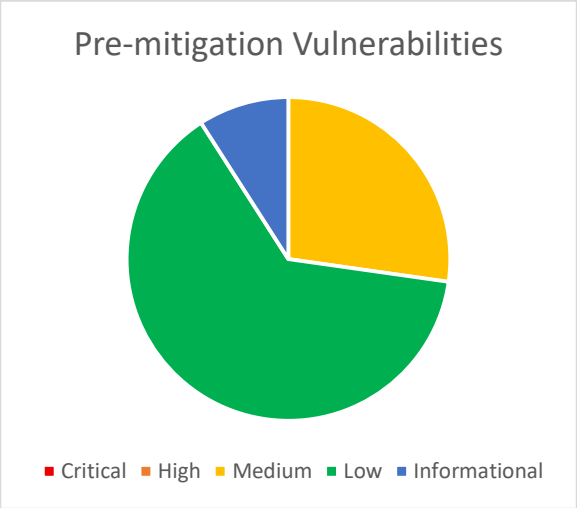
PUBLIC SAMPLE © 2026 CYBERVSI

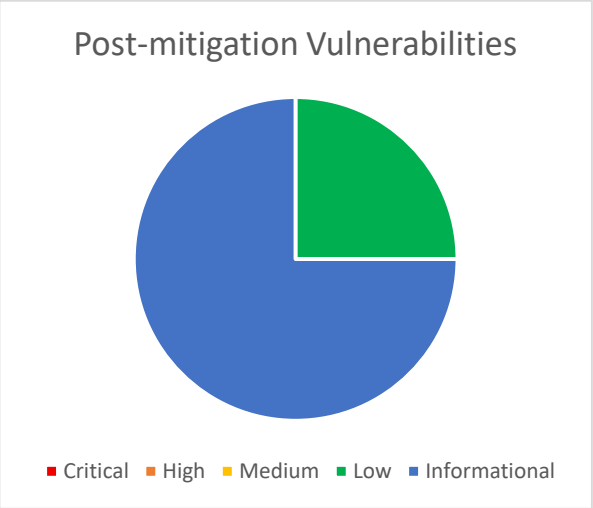
3.5 Scope of Assessment

Particulars	Details
Target Asset	*1 Web application*
Application Overview	*Internal ASP.NET application, is being used for investment reports by* Sample Organization
Name of the Application	Sample Customer Portal
Target URL of Web application	https://portal.example.test Sample Portal
Test Environment	*Production*
Initial Assessment Period	*16/09/2025 to 22/09/2025 – Phase1* *23/09/2025 to 26/09/2025 – Phase2*
Re-test URL	*N/A*
Security posture rating of the application before Mitigation of Web application	*7.4*
Security posture rating of the application after Mitigation of web application	*9.6*

3.6 Graphical Summary of the Key Findings

The following comprehensive chart illustrates the vulnerabilities found during the assessment in both web application and thick client application:

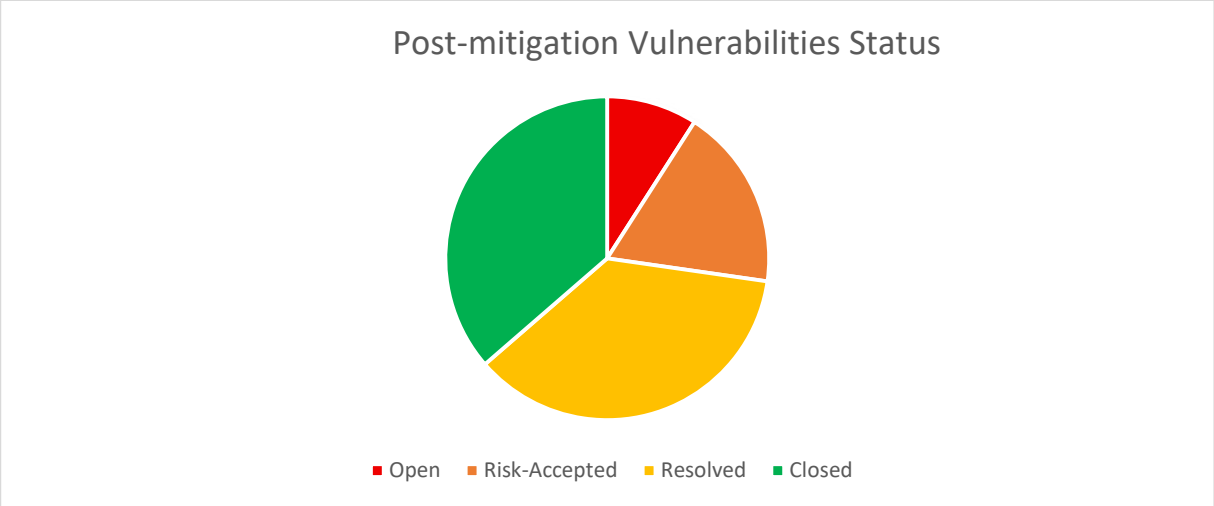




PUBLIC SAMPLE © 2026 CYBERVSI

Severity	Pre-mitigation Vulnerabilities count	Post-mitigation Vulnerabilities count
Critical	0	0
High	0	0
Medium	3	0
Low	7	2
Informational	1	5

3.7 Comprehensive vulnerability status post-mitigation



Vulnerability Status	Count
Open	1
Risk-Accepted	2
Resolved	4
Closed	4

PUBLIC SAMPLE © 2026 CYBERVSI

3.8 Vulnerability Overview – Status, Severity & CVSS Ratings

Sr. No	Vulnerabilities	OWASP Top 10	CVSS 3.1	Severity	Status
1	Use of Deprecated Cipher – Triple DES	A02:2021	5.9	Medium	Closed
2	Old TLS version Enabled	A05:2021	5.9	Medium	Closed
3	Use of Vulnerable Software Components	A06:2021	2.6	Low	Risk-Accepted
4	Business Logic Error	A04:2021	2.0	Low	Closed
5	Insecure CSRF Token Transmission via URL and GET Method	A05:2021	2.0	Low	Closed
6	Potential DOM XSS	A03:2021	1.8	Low	Resolved
7	Data Base Connection String disclosure	A04:2021	0.0	Info	Resolved
8	Internal IP Disclosure	A04:2021	0.0	Info	Resolved
9	DEBUG enabled	A04:2021	0.0	Info	Resolved
10	Admin Session Concurrency	A07:2021	0.0	Info	Risk-Accepted
11	Using the Default Cookie Name	A05:2021	0.0	Info	Open

PUBLIC SAMPLE © 2026 CYBERVSI

4. DETAILS OF IDENTIFIED VULNERABILITIES IN WEB APPLICATION

1. Use of Deprecated Cipher — Triple DES

Description:

The server supports the weak 64-bit block cipher **3DES (Triple DES)** under multiple TLS versions (TLS 1.0, 1.1, 1.2). This cipher is vulnerable to the **SWEET32 attack**, which allows an attacker to recover parts of the plaintext from long-lived TLS sessions. Continued support for outdated ciphers undermines the security of encrypted communication.

Status	Closed
Severity	Medium
CVSS 3.1	5.9
Base Vector String of CVSS 3.1	CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:N
Attack vector [AV]: N Attack Complexity [AC]: H Privileges Required [PR]: L User Interaction [UI]: N	Scope[S]: U Confidentiality [C]: N Integrity [I]: N Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-326**: Inadequate Encryption Strength **CWE-327**: Use of a Broken or Risky Cryptographic Algorithm.
OWASP Top 10 mapping	**OWASP (2021) - A02:** Cryptographic Failures

Affected target	https://portal.example.test/sample-path

Impact:

- Exploitable via a man-in-the-middle (MITM) attack on long-lasting TLS connections.
- Confidentiality of sensitive information (such as credentials, financial or personal data) may be compromised.
- Non-compliance with modern security standards (PCI DSS, NIST, ISO 27001).
- Increased risk of service being flagged as insecure by browsers and vulnerability scanners.

Steps to Reproduce:

1. Use Nmap to validate the TLS.
2. In the terminal, input the following nmap command: nmap –script –ssl-enum-ciphers <application domain name>
3. Observe the result of the TLS and the cipher in use from the outcome.

PUBLIC SAMPLE © 2026 CYBERVSI

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

- **Disable 3DES** (TLS cipher suites using 3DES): remove TLS_RSA_WITH_3DES_EDE_CBC_SHA and any 64-bit block ciphers from server config.
- **Disable TLS 1.0 and TLS 1.1** globally (if still enabled). Prefer TLS 1.2+ with modern ciphers or TLS 1.3.
- **Enable strong AEAD ciphers** only (e.g., AES-GCM, CHACHA20-POLY1305) and prioritize ECDHE key exchange.
- **Enforce forward secrecy** (ECDHE suites) where possible.

Evidence of fix:

SANITIZED SAMPLE EVIDENCE

SANITIZED SAMPLE EVIDENCE

PUBLIC SAMPLE © 2026 CYBERVSI

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Conclusion:

After fix, the DES 56 and Triple DES ciphers have been disabled with Order list defined for TLS 1.2 as follows:
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
TLS_ECDHE_EXDSA_WITH_AES_256_GCM_SHA384

DES 56, RC4 128/128, RC4 40/128, RC4 56/128, Triple DES 168 ciphers have been disabled. Hence, this vulnerability has been marked as closed based on the evidence of fix provided by Sample Organization team.

PUBLIC SAMPLE © 2026 CYBERVSI

2. Old TLS Version Enabled

Description:

The application supports outdated versions of the Transport Layer Security (TLS) protocol (e.g., TLS 1.0 or TLS 1.1), which are known to have cryptographic weaknesses. These versions are deprecated by major standards bodies and pose risks such as insecure cipher suites, lack of forward secrecy, and susceptibility to downgrade attacks.

Status	Closed
Severity	Medium
CVSS 3.1	5.9
Base Vector String of CVSS 3.1	CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:L/A:N
Attack vector [AV]: N Attack Complexity [AC]: H Privileges Required [PR]: L User Interaction [UI]: N	Scope[S]: U Confidentiality [C]: H Integrity [I]: L Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-326**: Inadequate Encryption Strength **CWE-327**: Use of a Broken or Risky Cryptographic Algorithm.
OWASP Top 10 mapping	**OWASP (2021) - A05:** Security Misconfiguration
Affected target	https://portal.example.test/sample-path

Impact:

- Exploitable via a man-in-the-middle (MITM) attack on long-lasting TLS connections.
- Confidentiality of sensitive information (such as credentials, financial or personal data) may be compromised.
- Non-compliance with modern security standards (PCI DSS, NIST, ISO 27001).
- Increased risk of service being flagged as insecure by browsers and vulnerability scanners.

Steps to Reproduce:

1. Use Nmap to validate the TLS.
2. In the terminal, input the following nmap command: ***nmap –-script ssl-enum-ciphers*** portal Sample Portal example.test
3. Observe the result of the TLS and the cipher in use from the outcome.

PUBLIC SAMPLE © 2026 CYBERVSI

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

On all servers and clients.

- Enforce TLS 1.2 or higher (preferably TLS 1.3).
- Update libraries and frameworks to support TLS 1.2 or TLS 1.3.
- Use strong cipher suites and enable forward secrecy.
- **Enable strong AEAD ciphers** only (e.g., AES-GCM, CHACHA20-POLY1305) and prioritize ECDHE key exchange.
- Test using SSL/TLS scanners (e.g., nmap, Qualys SSL Labs, testssl.sh).

Evidence of fix:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

PUBLIC SAMPLE © 2026 CYBERVSI

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Conclusion:

After fix, the old TLS versions (TLS 1.0 and 1.1) have been disabled and Only TLS 1.2 has been enabled for both client and server. Hence, this issue has been marked as closed.

PUBLIC SAMPLE © 2026 CYBERVSI

3. Use of Vulnerable Software Components

Description:

This web application relies on outdated third-party components with publicly known vulnerabilities, including Bootstrap 3.3.4, jQuery 1.11.2, jQuery 1.12.4, jQuery Impromptu 3.0, and CodeMirror 6.54.0 . Continued use of these components exposes the application to risks such as cross-site scripting (XSS), DOM manipulation attacks, and other client-side security issues.

This issue has been reported with severity as Medium because exploitation depends on specific conditions, such as the component being directly exposed to untrusted user input. While the vulnerabilities are real and well-documented, they typically require chaining with other attack vectors for significant impact.

Status	Risk-Accepted
Severity	Low
CVSS 3.1	2.6
Base Vector String of CVSS 3.1	CVSS:3.1/AV:A/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:N
Attack vector [AV]: A Attack Complexity [AC]: H Privileges Required [PR]: L User Interaction [UI]: N	Scope[S]: U Confidentiality [C]: N Integrity [I]: L Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-1104**: Use of Unmaintained Third-Party Components
OWASP Top 10 mapping	**OWASP (2021) - A06:** Vulnerable and Outdated Components
Affected target	https://portal.example.test/sample-path

The use of outdated and vulnerable components (Bootstrap 3.3.4, jQuery 1.11.2, jQuery 1.12.4, jQuery Impromptu 3.0, and CodeMirror 6.54.0) may expose the application to client-side attacks such as cross-site scripting (XSS), DOM-based manipulation, and injection vulnerabilities. Successful exploitation could allow an attacker to:

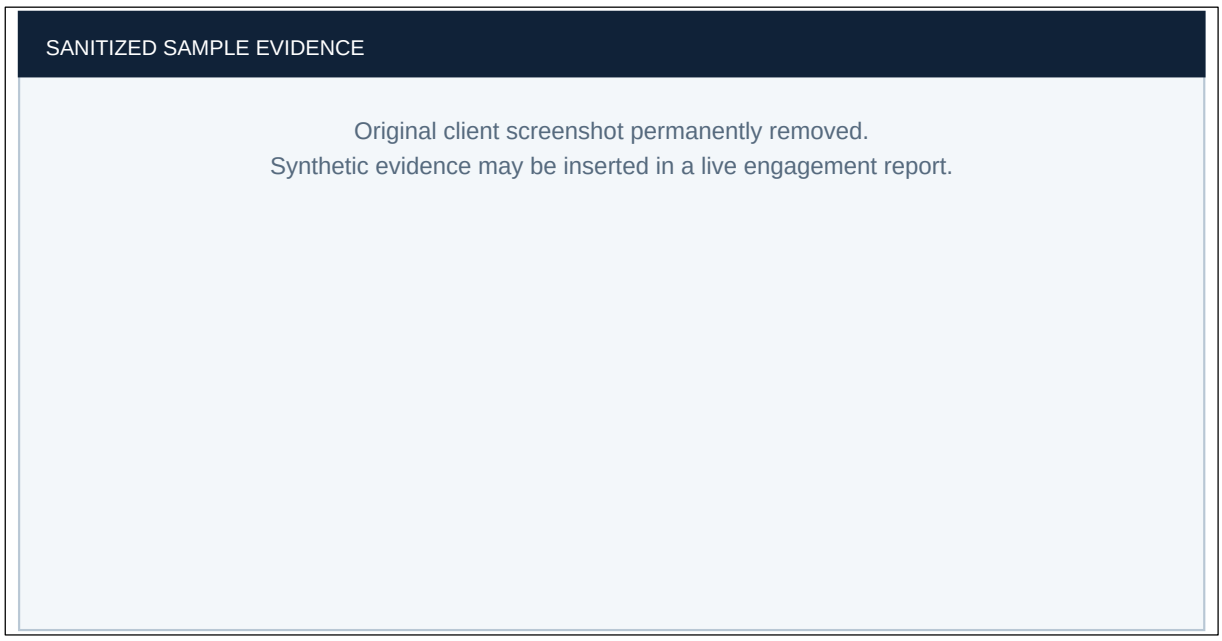
- Steal sensitive information such as session cookies, authentication tokens, or user data.
- Manipulate or deface application content, reducing user trust.
- Use XSS or DOM injection as a pivot to deliver malware or phishing payloads.
- Chain the vulnerability with other weaknesses to escalate impact, potentially reaching account compromise or unauthorized access.

PUBLIC SAMPLE © 2026 CYBERVSI

Steps to Reproduce:

1. Access application on the browser.
2. Use browser developer tools (F12), a proxy such as Burp Suite to review loaded JavaScript and CSS resources or retire.js extension.
3. Identify component versions.
4. Confirm that the detected versions are outdated or vulnerable by comparing them with:
   a. Vendor release notes
   b. CVE databases (e.g., NVD, MITRE)
   c. OWASP dependency check or similar SCA tools

Proof of Concept:



Remediation:

- Use Software Composition Analysis (SCA) to detect outdated or vulnerable dependencies.
- Maintain a Software Bill of Materials (SBOM) to track all components.
- Apply timely patches and updates.
- Implement Web Application Firewalls (WAFs) for virtual patching.
- Integrate security into CI/CD pipelines for early detection.

PUBLIC SAMPLE © 2026 CYBERVSI

Risk Acceptance Details:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Conclusion:

As per the risk acceptance details provided by Sample Organization Team, the vulnerable software components cannot be upgraded at this time, as newer versions may introduce compatibility issues that could disrupt existing website functionality, business operation and user experience. Considering the compensating controls in place, including a Web Application Firewall (WAF) to block suspicious requests, IAM for access control enforcement, Palo Alto firewalls for malicious traffic prevention, network controls such as NACLs and security groups to restrict unauthorized connections, and server hardening measures the severity of this issue has been downgraded from **Medium** to **Low** and recommended to upgrade all vulnerable software components to the latest, non-vulnerable stable versions by agreed fix-deadline. The CVSS and CVSS vector strings have been updated, accordingly. Hence, this vulnerability has been marked as risk-accepted.

PUBLIC SAMPLE © 2026 CYBERVSI

4. Business Logic Error

Description:

The web application allows users to select a **backward date range** (e.g., *from 19/09/2025 to 18/09/2025*). This violates expected business rules, as a "start date" should always be earlier than the "end date." Such logic flaws may allow users to bypass validations, create inconsistent records, or trigger unexpected behaviors in reporting and workflows

Status	Closed
Severity	Low
CVSS 3.1	2.0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:N/I:L/A:N
Attack vector [AV]: N Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: L Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-841:** Improper Enforcement of Behavioral Workflow
Affected target	https://portal.example.test/sample-path

- **Data Integrity Issues**: Reports, transactions, or records may reflect invalid ranges, leading to misleading results.
- **Bypass of Controls**: Attackers could exploit backward ranges to avoid validation rules (e.g., expiry checks, billing cycles).
- **Business Process Disruption**: May cause calculation errors, incorrect billing, or faulty decision-making in financial or operational workflows.
- **Potential for Chaining**: When combined with other vulnerabilities, such as improper validation elsewhere, could lead to privilege abuse or fraud

PUBLIC SAMPLE © 2026 CYBERVSI

Steps to Reproduce:

1. Log in to the application.
2. Navigate to Myreport and date filter for report generation.
3. Set the **Start Date** to a later date (e.g., 19/09/2025).
4. Set the **End Date** to an earlier date (e.g., 18/09/2025).
5. Submit the form.
6. Observe that the application accepts the invalid input without enforcing proper validation.

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

1. Enforce **server-side validation** to ensure that the **start date is always earlier than the end date**.
2. Reject or auto-correct invalid input ranges
3. Define and enforce clear business rules for all input fields and workflows.

Conclusion:

Based on the justification provided by the Sample Organization team, the reported vulnerability has no system or application-level impact and is a design flaw, only. The generated report is also a blank report and does not pose any risk related to improper business logic. Also, considering the compensating controls in place, including a Web Application Firewall (WAF) to block suspicious requests, IAM for access control enforcement, Palo Alto firewalls for malicious traffic prevention, network controls such as NACLs and security groups to restrict unauthorized connections, and server hardening measures the severity of this issue has been downgraded from ***Medium*** to ***Low*** and recommended to upgrade all vulnerable software components to the latest, non-vulnerable stable versions by agreed fix-deadline. The CVSS and CVSS vector strings have been updated, accordingly. Hence, this vulnerability has been marked as closed.

PUBLIC SAMPLE © 2026 CYBERVSI

5. Insecure CSRF Token Transmission via URL and GET Method

Description:

Transmitting CSRF tokens via URL and GET method is insecure because:

- Tokens can leak through browser history, server logs, and Referrer headers.
- GET requests are cacheable, risking token exposure.
- CSRF protection fails if tokens are reused or intercepted.

Status	Closed
Severity	Low
CVSS 3.1	2.0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:N/I:L/A:N
Attack vector [AV]: N Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: L Availability[A]: N
Common Weakness Enumeration (CWE)	CWE-598: Use of GET Request Method With Sensitive Query Strings

Affected target	https://portal.example.test/sample-path

- Data Leakage: Sensitive info (e.g., passwords, tokens) may be exposed in browser history, server logs, and analytics tools.
- Referrer Header Exposure: URLs shared across domains can leak data to third-party sites via HTTP Referrer headers.
- Cache Risks: GET requests are often cached, potentially storing sensitive data in proxies or browsers.
- CSRF Attacks: CSRF protection fails if tokens are reused or intercepted which leads to CSRF and

Affected target	https://portal.example.test/sample-path

PUBLIC SAMPLE © 2026 CYBERVSI

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

- Never include sensitive data (e.g., passwords, tokens, personal info) in URLs.
- Use POST requests with secure headers or encrypted payloads.

Conclusion:

Based on the justification provided by the Sample Organization team, the reported Anti-CSRF token will be generated post user clicks on logout and cannot be re-used in any of the requests for re-authentication. Also, considering the compensating controls in place, including a Web Application Firewall (WAF) to block suspicious requests, IAM for access control enforcement, Palo Alto firewalls for malicious traffic prevention, network controls such as NACLs and security groups to restrict unauthorized connections, and server hardening measures this issue has been marked as closed.

PUBLIC SAMPLE © 2026 CYBERVSI

6. Potential DOM XSS

Description:

DOM-based XSS occurs when client-side JavaScript dynamically updates the DOM using unsanitized user input, allowing malicious scripts to execute in the browser.

In this case, the presence of:<script> payload suggests that user input is being directly injected into the page without proper sanitization. The onmouseover and onmouseout handlers also indicate dynamic DOM manipulation, which may be vulnerable if values are derived from user-controlled sources.

Status	Resolved
Severity	Low
CVSS 3.1	1.8
Base Vector String of CVSS 3.1	CVSS:3.1/AV:A/AC:H/PR:H/UI:R/S:U/C:N/I:L/A:N
Attack vector [AV]: A Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: L Availability[A]: N
Common Weakness Enumeration (CWE)	CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')
Affected target	https://portal.example.test/sample-path

- Session Hijacking: Attackers can steal login tokens.
- Data Theft: Sensitive user input like passwords can be captured.
- Malicious Redirection: Users may be sent to phishing or malware sites.
- Admin Abuse: If triggered in privileged contexts, it can lead to full system compromise.

PUBLIC SAMPLE © 2026 CYBERVSI

Steps to Reproduce:

1. Log in to the user account.
2. Navigate to My reports and select a report.
3. Click on edit to edit the report name.
4. Add the Payload <script>alert("test for XSS")</scipt>
5. Observe the DOM response with onmouseover and onmouseout handlers on the screen .

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

- **Sanitize Input**: Use libraries like DOMPurify to clean user input before injecting into the DOM.
- **Avoid innerHTML**: Prefer safer methods like textContent or setAttribute.
- **Content Security Policy (CSP)**: Implement CSP headers to restrict script execution.
- **Validate and Encode**: Encode output properly and validate input on both client and server sides.

Conclusion:

As per the justification given by Sample Organization team, the compensating controls are in place, including a Web Application Firewall (WAF) to block suspicious requests, IAM for access control enforcement, Palo Alto firewalls for malicious traffic prevention, network controls such as NACLs and security groups to restrict unauthorized connections, and server hardening measures. Hence the **CVSS has been downgraded** and CVSS vector string has been updated, considering the **low likelihood of attack** and this vulnerability has been marked as resolved. It is recommended to implement application/code level input sanitisation/validation to mitigate this issue.

PUBLIC SAMPLE © 2026 CYBERVSI

7. Database Connection String Disclosure

Description:

A database connection string specifies information about a data source and the means of connecting to it. In web applications, connection strings are generally used by the application tier to connect to the back database used for storing application data. They are usually read from server-side configuration files or hard-coded into application source code.

Issue remediation

It is almost never necessary for applications to disclose database connection strings to clients. The

Sanitized connection-string example:

```
datasource=sample-db; username=sample_user; password=***
```

Original database names, hosts, usernames and secrets permanently removed.

Status	Resolved
Severity	Info
CVSS 3.1	0.0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:A/AC:H/PR:H/UI:R/S:U/C:N/I:N/A:N
Attack vector [AV]: A Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: N Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-201:** Insertion of Sensitive Information Into Sent Data
OWASP Top 10 mapping	**OWASP (2021) – A04**: Insecure Design

Affected target	https://portal.example.test/sample-path

PUBLIC SAMPLE © 2026 CYBERVSI

Impact:

- **Unauthorized Access**: If attackers obtain a connection string with credentials, they can directly access the database and potentially extract, modify, or delete data.
- **Privilege Escalation**: If the connection string uses high-privilege accounts (e.g., admin or root), attackers may gain full control over the database server.
- **Injection Attacks**: Disclosure can lead to connection string injection, where attackers manipulate the string to execute malicious SQL commands

Steps to Reproduce:

Affected target	https://portal.example.test/sample-path

4. Observe the database details in the response

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

1. Debug mode often exposes sensitive information in logs or error message. Turn it off in production environments and restrict its use to secure development environments only with additional login, if required.
2. Ensure connection strings are not hardcoded or exposed in the UI, logs, or error messages
3. Assume the credentials have been compromised. Generate new database usernames/passwords and update your app configuration securely

PUBLIC SAMPLE © 2026 CYBERVSI

Evidence of fix:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Conclusion:

Based on the justification and evidence provided by the Sample Organization team “the reported vulnerability in debug mode is accessible only to the admin user. It is also validated that the DB connection string in the response is not accessible by non-application user. After verifying with the DB team, the hardcoded credentials are confirmed to be of a non-privileged application user account with no elevated access, and it is centrally managed by CyberArk with password rotation and restricted credential access. The account is used only for application functions and does not allow interactive or manual login, which limits exposure. Its activity is monitored and logged, and the system is further protected by existing controls such as endpoint and network restrictions. With these controls in place, the risk is effectively mitigated”.

As this is an internal application with restricted user access, supported by a Web Application Firewall (WAF) and well-implemented system hardening measures, the severity of this issue has been downgraded from ***Low*** to ***Informational*** and marked as resolved. Though an immediate remediation is not necessary it is recommended to disable debug mode even to admin user in production environment or remove the sensitive details like connection strings, Internal Ips, hardcoded credentials etc.. from the response which leads to information disclosure via MITM attacks.

PUBLIC SAMPLE © 2026 CYBERVSI

8. Internal IP Disclosure

Description:

This vulnerability occurs when a super admin login interface or dashboard reveals the internal IP address. Such exposure can be dangerous because internal IPs are meant to remain hidden from external users and attackers. This may pose the risk of IP disclosure in MITM attacks when these IPs or any other sensitive information is hardcoded.

Status	Resolved
Severity	Info
CVSS 3.1	0.0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:A/AC:H/PR:H/UI:R/S:C/C:N/I:N/A:N
Attack vector [AV]: A Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: C Confidentiality [C]: N Integrity [I]: N Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-201:** Insertion of Sensitive Information Into Sent Data
OWASP Top 10 mapping	**OWASP (2021) – A04**: Insecure Design

Affected target https://portal.example.test/sample-path

- **Network Mapping**: Attackers can use the disclosed IP to map the internal infrastructure, aiding lateral movement in case of a breach.
- **Targeted Attacks**: Knowing the internal IP allows attackers to craft more precise exploits, especially in hybrid or misconfigured environments.
- **Cloud Exposure**: In cloud setups, internal IPs may link to specific services or instances, increasing the risk of service enumeration or privilege escalation.

PUBLIC SAMPLE © 2026 CYBERVSI

Steps to Reproduce:

Affected target	https://portal.example.test/sample-path

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

- Debug mode often exposes sensitive information in logs or error message. Turn it off in production environments and restrict its use to secure development environments only with additional login, if required.
- Ensure internal IPs are not hardcoded or exposed in the UI, logs, or error messages

Evidence of fix:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

PUBLIC SAMPLE © 2026 CYBERVSI

Conclusion:

Based on the justification and evidence provided by the Sample Organization team “the reported vulnerability in debug mode is accessible only to the admin user. Its activity is monitored and logged, and the system is further protected by existing controls such as endpoint and network restrictions. With these controls in place, the risk is effectively mitigated”.

As this is an internal application with restricted user access, the IP disclosure may not possess a severe risk as the application is supported by a Web Application Firewall (WAF) and well-defined system hardening measures Hence, the severity of this issue has been downgraded from ***Low*** to ***Informational*** and marked as resolved. Though an immediate remediation is not necessary it is recommended to disable debug mode even to admin user in production environment or remove the sensitive details like connection strings, Internal IPs, hardcoded credentials etc.. from the response which leads to information disclosure via MITM attacks.

PUBLIC SAMPLE © 2026 CYBERVSI

9. DEBUG Enabled

Description:

Enabling **debug mode** in a web application typically refers to activating a special configuration that provides developers with enhanced visibility into the app's internal workings. While invaluable during development, it can pose serious risks if left active in production. Just because it's a defined functionality in an internal admin interface doesn't automatically make it safe, having proper user authentication and access control significantly reduces the risk. However, even with those protections, a /debug endpoint can still pose a **security vulnerability** if not carefully designed.

This vulnerability has been classified with **Low severity** due to its exposure being limited to the **Admin user interface** where **Debug Mode** is enabled. During testing (Phase2), access to lower-privilege user accounts was restricted, preventing validation of whether the same debug information is exposed to non-admin users.

Status	Resolved
Severity	Info
CVSS 3.1	0.0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:A/AC:H/PR:H/UI:R/S:U/C:N/I:N/A:N
Attack vector [AV]: N Attack Complexity [AC]: L Privileges Required [PR]: L User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: N Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-489**: Active Debug Code
OWASP Top 10 mapping	**OWASP (2021)- A04**: Insecure Design

Affected target	https://portal.example.test/sample-path

PUBLIC SAMPLE © 2026 CYBERVSI

Impact:

- **Privilege Escalation:** If the debug endpoint exposes internal state, configuration, or sensitive operations, a compromised admin account could be used to escalate privileges or pivot deeper into the system.
- **Sensitive Data Exposure:** Debug endpoints often reveal, Environment variables (e.g., API keys, DB credentials), Stack traces or error messages, Internal logic or file paths
  Even authenticated users shouldn't necessarily see all of this.
- **Misuse by Insider Threats**
- **Lack of Audit or Rate Limiting**: If the endpoint isn't monitored or rate-limited, it could be abused for reconnaissance or brute-force testing.
- **Debug Features That Alter State:** If /debug allows modifying configurations, toggling features, or executing code, it becomes a high-risk surface for abuse.

Steps to Reproduce:

1. Login to the Admin Account and navigate to the Review in Debug mode.
2. Observe that the DEBUG mode discloses the sensitive details like DB connection string, username, IP etc..using burp proxy.

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

PUBLIC SAMPLE © 2026 CYBERVSI

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

Disable debug mode in production environments irrespective of user role, in the application.

Evidence of fix:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

PUBLIC SAMPLE © 2026 CYBERVSI

Conclusion:

Based on the justification and evidence provided by the Sample Organization team “the reported vulnerability in debug mode is accessible only to the admin user. It is also validated that the DB connection string in the response is not accessible by non-application user. After verifying with the DB team, the hardcoded credentials is of a non-privileged application user account with no elevated access, and it is centrally managed by CyberArk with password rotation and restricted credential access. The account is used only for application functions and does not allow interactive or manual login, which limits exposure. Its activity is monitored and logged, and the system is further protected by existing controls such as endpoint and network restrictions. With these controls in place, the risk is effectively mitigated”.

As this is an internal application with restricted user access, supported by a Web Application Firewall (WAF) and well-defined system hardening measures, the severity of this issue has been downgraded from ***Low*** to ***Informational*** and marked as resolved. Though an immediate remediation is not necessary it is recommended to disable debug mode even to admin user in production environment or remove the sensitive details like connection strings, Internal Ips, hardcoded credentials etc.. from the response which leads to information disclosure via MITM attacks.

PUBLIC SAMPLE © 2026 CYBERVSI

10. Admin Session Concurrency

Description:

The application allows multiple concurrent sessions for the same administrative account without restriction or notification. This means an admin user can be logged in simultaneously from multiple devices or browsers, which increases the risk of unauthorized access, session hijacking, and privilege abuse—especially if credentials are compromised or shared.

Status	Risk-Accepted
Severity	Info
CVSS 3.1	0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:A/AC:H/PR:H/UI:R/S:U/C:N/I:N/A:N
Attack vector [AV]: A Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: N Availability[A]: N
Common Weakness Enumeration (CWE)	**CWE-362:** Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition')

Affected target https://portal.example.test/sample-path

- Session Hijacking: Attackers can maintain access even after the legitimate user logs in elsewhere.
- Privilege Abuse: Concurrent sessions may allow unauthorized users to perform admin-level actions unnoticed.
- Increased Attack Surface: More active sessions mean more opportunities for exploitation.
- Potential Account take over.

Steps to Reproduce:

1. Login using admin credentials
2. Login to the same account in different browser instance.
3. Observe the successful concurrent login.

PUBLIC SAMPLE © 2026 CYBERVSI

Proof of Concept:

SANITIZED SAMPLE EVIDENCE	SANITIZED SAMPLE EVIDENCE
Original client screenshot permanently removed. Synthetic evidence may be inserted in a live engagement report.	Original client screenshot permanently removed. Synthetic evidence may be inserted in a live engagement report.
SANITIZED SAMPLE EVIDENCE	**SANITIZED SAMPLE EVIDENCE**
Original client screenshot permanently removed. Synthetic evidence may be inserted in a live engagement report.	Original client screenshot permanently removed. Synthetic evidence may be inserted in a live engagement report.

Remediation:

- Limit admin accounts to one active session.
- Bind sessions to device/IP.
- Enforce timeouts.
- Enable login alerts, and provide session monitoring to prevent concurrency risks.

Risk Acceptance Details:

SANITIZED SAMPLE EVIDENCE
Original client screenshot permanently removed. Synthetic evidence may be inserted in a live engagement report.

Conclusion:

As per the justification provided by Sample Organization business for end users to open mul Customer Portal accepted and the CVSS and CVSS vector strings hav he concurrence is the normal course of across different monitors. Hence, risk updated, accordingly.

PUBLIC SAMPLE © 2026 CYBERVSI

11. Using the Default Cookie Name

Description:

The application issues session cookies with default names (ASP.NET_SessionId). While the cookie attributes (Secure, HttpOnly, SameSite) and session management controls are correctly configured, the use of default cookie names exposes underlying framework details. This can aid attackers in fingerprinting the application stack during reconnaissance.

Status	Open
Severity	Info
CVSS 3.1	0
Base Vector String of CVSS 3.1	CVSS:3.1/AV:N/AC:H/PR:H/UI:R/S:U/C:N/I:N/A:N
Attack vector [AV]: N Attack Complexity [AC]: H Privileges Required [PR]: H User Interaction [UI]: R	Scope[S]: U Confidentiality [C]: N Integrity [I]: N Availability[A]: N
Common Weakness Enumeration (CWE)	N/A
OWASP Top 10 mapping	**OWASP (2021) – A05**: Security Misconfiguration
Affected target	https://portal.example.test/sample-path

Impact:

- Reveals underlying framework/technology (e.g., PHP, Java, ASP.NET), which may assist attackers in tailoring exploits.
- Alone, this does not compromise session security, as all cookie protections are correctly configured.

Steps to Reproduce:

1. Log in to the application.
2. Inspect cookies using browser developer tools or an HTTP proxy.
3. Observe the cookie name (ASP.NET_SessionId).

PUBLIC SAMPLE © 2026 CYBERVSI

Proof of Concept:

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

SANITIZED SAMPLE EVIDENCE

Original client screenshot permanently removed.
Synthetic evidence may be inserted in a live engagement report.

Remediation:

- Optionally configure the application to use **custom cookie names** (e.g., app_sess) instead of framework defaults.
- Continue enforcing strong cookie attributes (Secure, HttpOnly, SameSite) and session management practices.
- Treat this as **hardening** rather than an urgent fix.

PUBLIC SAMPLE © 2026 CYBERVSI

5. POST-INITIAL ENGAGEMENT REVIEW and SECURITY RECOMMENDATIONS

The findings presented in this section reinforce critical observations identified during the Web Application Security. Vulnerabilities have been categorized by severity and contextualized based on their potential business impact and exploitability based on CVSS 3.1. This classification serves as a foundation for prioritizing remediation efforts and strengthening the organization's overall security posture.

Through rigorous testing and validation, the report highlights key exposure points, systemic misconfigurations, and opportunities for enhancement in policy, architecture, and operational controls. The forward actions outlined herein are designed to support risk mitigation, inform decision-makers, and guide continuous improvement initiatives within Sample Organization

We appreciate the collaborative support received throughout the assessment, and we remain available to assist with remediation validation, follow-up testing, or strategic guidance for long-term security improvements.

Observations:

- 3-Medium, 7-Low and One- Informational, severity vulnerabilities were discovered in the Web application that pose a substantial risk to operational availability, integrity and data confidentiality.
- 2-Medium severity vulnerabilities were discovered in the Thick-client application that pose a substantial risk to operational availability, integrity and data confidentiality in web Application.
- OWASP Top 10 Web application Vulnerabilities Identified across the Sample Customer Portal web application:
  Broken Access Control (OWASP A02:2021)
  Injection (OWASP A03:2021)
  Insecure Design (OWASP A04:2021)
  Security Misconfigurations (OWASP A05:2021)
  Vulnerable and outdated components (OWASP A06:2021)
  Identification and Authentication Failure (OWASP A07:2021)
- Positive indicators: proper CORS validation prevents unauthorized cross-origin access, no SSRF vulnerabilities ensure backend protection, and absence of severe injection flaws confirms robust input handling covering the Broken Access Control (OWASP A01:2021), Software and Data Integrity Failure (OWASP A08:2021), Security Logging and Monitoring Failures (OWASP A09:2021) and Server-Side Request Forgery (OWASP A10:2021)
- Not covered: Due to production environment constraints and limited permissions, several high-impact test scenarios were not covered. These include vertical privilege escalation across multiple roles, unlimited .DDL Hijacking operations, and other disruptive test cases.
- Overall Security Posture of the web application before mitigation: Moderately Vulnerable.

Forward Actions:

To address the identified issues and fortify the security posture of Sample Organization the following actions are recommended:

- Immediate Remediation: Prioritize patching and configuration fixes for Medium-risk vulnerabilities.

PUBLIC SAMPLE © 2026 CYBERVSI

- **Security Awareness & Training:** Educate development and operations teams on secure coding, threat modelling, and incident response.
- **Policy Reinforcement:** Review and update security policies to include vulnerability management, periodic audits, and escalation protocols.
- **Retesting Plan:** Schedule follow-up assessments to validate remediation efforts and assess security improvements.
- **Integration of Security Tools:** Adopt continuous monitoring solutions and automated scanning tools in the CI/CD pipeline.

6. POST-FINAL ENGAGEMENT REVIEW and SECURITY RECOMMENDATIONS

The findings presented in this section reinforce critical observations identified during the Web Application Security, Post-mitigation. Vulnerabilities have been categorized by severity and contextualized based on their potential business impact and exploitability based on CVSS 3.1. This classification serves as a foundation for prioritizing remediation efforts and strengthening the organization's overall security posture.

Through rigorous testing and validation, the report highlights key exposure points, systemic misconfigurations, and opportunities for enhancement in policy, architecture, and operational controls. The forward actions outlined herein are designed to support risk mitigation, inform decision-makers, and guide continuous improvement initiatives within Sample Organization

We appreciate the collaborative support received throughout the assessment, and we remain available to assist with remediation validation, follow-up testing, or strategic guidance for long-term security improvements.

Observations:

- **Out of 3-Medium severity vulnerabilities reported –** two issues have been closed; one has been risk accepted and downgraded to Low.
- **Out of 7-Low** severity vulnerabilities reported – 2 issues have been closed based on business justifications and the rest of the vulnerability have been resolved by downgrading the CVSS/severity considering the security implementations in place for system, server and network.
- **Considering the overall** severity of risk-accepted, closed and resolved vulnerabilities along with one informational vulnerability reported during initial assessment, the total number of **Informational** issues altogether are as follows:
  3- Resolved (from low severity)
  1- Risk Accepted (downgraded from medium to info)
  1-Open (1 earlier reported)
- **Positive indicators**: Web Application Firewall (WAF) to block suspicious requests, IAM for access control enforcement, Palo Alto firewalls for malicious traffic prevention, network controls such as NACLs and security groups to restrict unauthorized connections, and server hardening measures have been implemented to achieve the security posture.
- **Limitations:** All vulnerabilities post-mitigation are Closed/Resolved/Risk-accepted based on the business justification and evidence provided by Sample Organization team, and no retest has been performed to verify the mitigation or said controls in place.

PUBLIC SAMPLE © 2026 CYBERVSI

- Overall Security Posture of the web application before mitigation: Moderately Secure.

Forward Actions:

To address the identified issues and fortify the security posture of Sample Organization the following actions are recommended:

- **Immediate Remediation:** Prioritize addressing the residual risks that have been risk-accepted, ensuring remediation is completed within the agreed fix deadlines.
- **Periodic Assessment:** Security is a continuous process rather than a one-time activity. While this assessment provides assurance of vulnerabilities identified at the time of testing, it does not guarantee complete coverage. To maintain a strong security posture, periodic or annual assessments are recommended.
- **Security Awareness & Training:** Provide ongoing education for development and operations teams on secure coding practices, threat modeling, and incident response procedures.
- **Policy Reinforcement:** Review and update organizational security policies to incorporate vulnerability management, periodic audits, and clear escalation protocols.
- **Retesting Plan:** Schedule internal follow-up assessments to validate remediation efforts and measure improvements in the application's security posture.
- **Integration of Security Tools:** Implement continuous monitoring solutions and automated scanning tools within the CI/CD pipeline to proactively identify and mitigate vulnerabilities.

7. COMPLIANCE MAPPING OF IDENTIFIED VULNERABILITIES

Purpose: This section maps the identified vulnerabilities to relevant compliance frameworks requirements of Sample Organization SOC 2 Trust Services Criteria and MAS TRM Domains—to support regulatory alignment and remediation prioritization. Compliance Interpretation for Additional Vulnerabilities

Compliance Interpretation:

SOC2 Type II:

- CC6.1 – Restricts Logical Access
  Vulnerabilities such as deprecated cipher usage, old TLS versions, DOM-based XSS, and default cookie names weaken access control boundaries and expose system resources to unauthorized access.
- CC6.2 – Implements Authentication Mechanisms
  Admin session concurrency and insecure CSRF token transmission via URL reflect weak session controls and poor identity verification, enabling unauthorized users to bypass authentication safeguards.
- CC7.1 – Monitors System Components
  Internal IP disclosure, debug mode enabled, and business logic errors indicate insufficient runtime monitoring and lack of automated detection for anomalous behaviour or misconfigurations.
- CC7.2 – Identifies and Remediates Vulnerabilities
  Use of vulnerable software components and unresolved references in thick-client applications highlight gaps in vulnerability scanning, patching cadence, and remediation workflows.

PUBLIC SAMPLE © 2026 CYBERVSI

- CC8.1 – Manages Change Securely
  Thick-client component vulnerabilities and deployment of outdated TLS protocols suggest weak change management practices and lack of secure SDLC enforcement.

MAS TRM Domains:

- Domain 3 – IT Security
  Covers failures in secure authentication, session management, input validation, and cryptographic controls. Vulnerabilities like admin session concurrency, CSRF token exposure, and deprecated cipher usage fall under this domain.
- Domain 4 – IT Operations Management
  Captures gaps in patching, monitoring, and operational oversight. Vulnerabilities such as debug mode enabled, unresolved thick-client references, and vulnerable software components reflect poor hygiene in production pipelines.
- Domain 8 – Application Security
  Emphasizes secure coding practices and protection against common web flaws. DOM XSS, business logic errors, and default cookie naming conventions indicate weak development controls.
- Domain 9 – Cybersecurity
  Addresses broader system hardening and secure configuration baselines. Internal IP disclosure, old TLS versions, and debug mode enabled expose configuration weaknesses across infrastructure layers.
- Domain 10 – Technology Architecture
  Reflects architectural misalignments in environment segregation and deployment hygiene. Thick-client vulnerabilities and insecure session concurrency reveal absence of layered defences and poor separation of duties.

OSPAR Domain Mapping:

- Domain 3.1 – Secure Application Development
  Highlights deficiencies in secure coding, input validation, and session integrity. Vulnerabilities such as DOM XSS, CSRF token exposure, and default cookie names reflect lack of secure-by-design principles.
- Domain 4.1 – Runtime Monitoring & Anomaly Detection
  Captures gaps in behavioural monitoring and detection of unauthorized actions. Issues like debug mode enabled, internal IP disclosure, and business logic errors indicate insufficient instrumentation.
- Domain 4.2 – Operational Security & Patch Management
  Addresses failures in patching cadence and secure deployment. Vulnerable software components and unresolved thick-client references suggest delayed remediation and weak operational oversight.
- Domain 9.1 – Infrastructure Hardening & Configuration Hygiene
  Reflects broader system misconfigurations. Deprecated cipher usage, old TLS versions, and internal IP exposure reveal gaps in header management and secure configuration.
- Domain 10.1 – Technology Architecture & Resilience
  Indicates architectural misalignments. Admin session concurrency and thick-client vulnerabilities expose poor environment segregation and insecure integration practices.

PUBLIC SAMPLE © 2026 CYBERVSI

Vulnerability-to-Compliance Mapping:

Vulnerability	SOC 2 TSC	MAS TRM Domains	Cyber Hygiene Practice	Control Focus Area	OSPAR Domains	OSPAR Mapping Summary
Use of Deprecated Cipher – Triple DES	CC6.1, CC7.1	Domain 3, 9	Cipher suite hardening, TLS config	Secure configuration, encryption hygiene	9.1	Weak cryptographic controls expose data in transit.
Old TLS Version Enabled	CC6.1, CC7.1	Domain 3, 9	TLS version enforcement, protocol hardening	Secure transmission, encryption hygiene	9.1	Enables downgrade attacks and weak encryption.
Use of Vulnerable Software Components	CC8.1, CC7.2	Domain 4, 10	Patch management, SBOM tracking	Vulnerability management, asset hygiene	4.2, 10.1	Indicates poor patch governance and third-party risk.
Admin Session Concurrency	CC6.2, CC7.1	Domain 3, 9	Session control, concurrency limits	Authentication hygiene, access control	3.1, 9.1	Violates session integrity and privilege boundaries.
Database Connection String Disclosure	CC6.1, CC7.1	Domain 3, 9	Secrets management, config obfuscation	Information disclosure hygiene	3.1, 9.1	Exposes sensitive credentials and backend access.
Potential DOM XSS	CC6.1, CC7.1	Domain 3, 8	DOM sanitization, CSP enforcement	Secure coding, runtime protection	3.1, 4.1	Risks client-side script injection and data theft.
Internal IP Disclosure	CC7.1	Domain 9	Header obfuscation, network masking	System hardening, information hygiene	9.1	Aids reconnaissance and internal network mapping.
Business Logic Error	CC6.1, CC7.1	Domain 3, 8	Logic validation, workflow enforcement	Secure design, anomaly detection	3.1, 4.1	Breaks functional integrity and user trust boundaries.
Insecure CSRF Token Transmission via URL/GET	CC6.1, CC7.1	Domain 3, 9	Token handling, secure transmission	Session integrity, access control hygiene	3.1, 9.1	Enables token leakage and CSRF exploitation.
Debug Enabled	CC6.1, CC7.1	Domain 9	Debug flag control, environment config	System hardening, exposure hygiene	9.1	Exposes internal logic and remote execution risks.
Using Default Cookie Name	CC6.1, CC7.1	Domain 3, 9	Cookie naming, session isolation	Secure configuration, session hygiene	3.1, 9.1	Facilitates session prediction and hijacking.

PUBLIC SAMPLE © 2026 CYBERVSI

8. DOCUMENT APPROVAL DETAILS

Document name	Web Application Security Assessment Report V2.1
Organization	CyberVSI
Submitted to	Sample Organization
Version	2.1 - Sanitized Sample
Classification	Public Sample
Category	Report
Created by	CyberVSI Security Testing Team
Contact email	connect@cybervsi.com
Approval	Sample document - no client approval required

PUBLIC SAMPLE © 2026 CYBERVSI